

SEC542 – Web Application Penetration Tester

Topics

Intro & Info Gathering

General Overview	542.1–5-39
Intro to ZAP/Burp	542.1–41-63
HTTP Syntax & Semantics	542.1–67-91
HTTP/Cookie Headers	542.1–91-101
Info Gathering/Discover/DNS/Port ..	542.1–103-136
Weak Ciphers/SSL/TLS	542.1–139-150
Spidering	542.1–153-163

Fuzzing, Scanning, Auth & Sessions

Fuzzing, Intruder, FFuF	542.2–5-17
Info Leakage & Directory Browsing ..	542.2–20-27
Burp Scanner	542.2–29-45
Forced Browsing & Kiterunner	542.2–48-53
HTTP & Form-based Authentication ..	542.2–56-72
SAML, OAUTH, & JWT	542.2–74-102
Harvesting	542.2–106-114
Session Management & Testing	542.2–118-131

Injection

Authentication/Authorization Bypass ..	542.3–5-13
Cmd Injection & Burp Collaborator ..	542.3–16-29
File Inclusion & Directory Traversal ..	542.3–32-36
XML External Entity(XXE)	542.3–39-46
Database Injection	542.3–49-68
Database Injection Categories	542.3–69-105
DB Fingerprinting & SQLMap	542.3–110-131

XSS, SSTI, Proto Pollution & SSRF 542.4–1-152

DOM & JavaScript/XSS & SOP Intro ..	542.4–5-28
XSS Impacts & BeEF	542.4–31-46
Classes of XSS	542.4–48-72
XSS Discovery	542.4–75-88
Prototype Pollution	542.4–91-101
AJAX/DOM Invader/JavaScript ..	542.4–104-119
Data attacks & SSTI	542.4–121-132
REST/SOAP & SSRF	542.4–135-150

CSRF, Serialization & Adv Tools 542.5–1-125

CSRF & Logic Flaws	542.5–5-17
LLM Top 10 & Logging Failures	542.5–20-31
Insecure Deserialization	542.5–33-51
Python & Python Pickling	542.5–53-79
Metasploit	542.5–81-90
Nuclei	542.5–92-98
Pentest Preparation	542.5–100-112
Pentest Post Assessment	542.5–114-123

Capture the Flag 542.1–1-22

Categories

Tools

Assestnote Wordlists	542.2–53
----------------------------	----------

BeEF	542.4–40-45
Bruno	542.4–140
Burp	542.1–49-62
Collaborator	542.3–24-26
Comparer	542.1–60
Dashboard	542.1–50
Decoder	542.4–54-55
Discover Content/Forced Browsing ..	542.2–50
DOM Invader	542.4–114-116
Engagement Tools	542.1–62
Intruder	542.1–56
—Attack Types/Fuzzing	542.2–9-13
Proxy HTTP History	542.1–55
Proxy Intercept	542.1–54
Scanner	542.2–29-45
—Add to task	542.2–39
—Configuration	542.2–35-38
—Passive & Active	542.2–29-32
—Results/Verification/Retest	542.2–40-45
Sequencer	542.1–58
Site Map - Filter	542.1–53
Spider/Crawling	542.1–159
Target - Scope	542.1–51
Target - Site Map	542.1–52
CeWL	542.1–162
DNSRecon	542.1–116-117
DOM Invader	542.4–114-116
FFuF	542.2–14-16
gowitness	542.1–131
Intruder → Burp	
Kiterunner	542.2–52
Nmap	542.1–129-130
Nuclei	542.5–92-97
Postman	542.4–139
SecLists	542.2–17
SoapUI	542.4–141
sqlmap	542.3–118-131
Auth/Session/Proxies	542.3–123-124
DB Enumeration & Data Exfil ..	542.3–128-130
Initial Targeting	542.3–122
Riding ZAP/Burp Sessions	542.3–125
SSLlabs	542.1–150
testssl	542.1–149
Ysoserial	542.5–49-50
ZAP	542.1–43-48
Add-ons	542.1–46
Attack Menu	542.1–45
Encoder	542.4–56
Forced Browse	542.2–51
Fuzzer	542.2–8
Import	542.1–47
Interface	542.1–44
Spider	542.1–160
Tools	542.1–48

Terminal Commands

curl	542.1–96
dig	542.1–113-114

SEC542 – Web Application Pentration Tester

nc	542.1-127
nslookup	542.1-112
wget	542.1-158

Labs

1.1-Configuring Interception Proxies ..	542.W1-2-22
1.2-Introducing Interception Proxies ..	542.W1-23-54
1.3 Virtual Host Discovery	542.W1-55-70
1.4-Gathering Server Information ..	542.W1-71-85
1.5-Testing HTTPS	542.W1-86-95
1.6-Web Spidering	542.W1-96-109
2.1-Intro to Fuzzing	542.W1-110-120
2.2-Vulnerability Scanning	542.W1-121-137
2.3-ffuf Forced Browsing	542.W1-138-146
2.4-Flask Session Cookies	542.W1-147-161
2.5-Attacking JSON Web Tokens	542.W1-162-177
2.6-Username Harvesting	542.W1-178-191
2.7-Blind Username Harvesting and Password Spraying	542.W1-192-212
2.8-Burp Sequencer	542.W1-213-230
2.Bonus-Authentication	542.W1-231-245
3.1-Authentication Bypass	542.W1-246-259
3.2-Command Injection	542.W1-260-284
3.3-Local/Remote File Inclusion ..	542.W1-284-291
3.4-XXE	542.W1-292-301
3.5-Error-based SQLi	542.W1-302-308
3.6-sqlmap + Burp	542.W1-309-338
4.1-HTML Injection	542.W2-1-11
4.2-BeEF	542.W2-12-27
4.3-DOM-Based XSS	542.W2-28-39
4.4-XSS	542.W2-40-53
4.5-Prototype Pollution	542.W2-54-79
4.6-SSTI	542.W2-80-105
4.7-Server-Side Request Forgery ..	542.W2-106-125
5.1-CSRF	542.W2-126-142
5.2-File Upload and Web Shell ...	542.W2-143-152
5.3-Insecure Deserialization	542.W2-153-167
5.4-Python	542.W2-168-177
5.5-Python Pickling	542.W2-178-211
5.6-Metasploit	542.W2-212-222
5.7-Nuclei and Jenkins	542.W2-223-240
5.Bonus-Python	542.W2-241-246
5.Bonus2- Exploiting Ruby on Rails	542.W2-247-261
5.Bonus3 - Drupalgeddon 2	542.W2-262-271

SEC542 – Web Application Penetration Tester

A

Access-Control-Allow-Origin/Creds	542.4–111-112
Active Scanning	542.2–29-32
AJAX	542.4–104-105
AJAX Spidering → Spidering	
Application Infrasture	542.1–132
Authentication	542.2–56-72
Basic	542.2–58-61
Bearer → Bearer Auth	
Burp	542.2–68
Digest	542.2–62-64
Form-Based	542.2–69-72
Schemes	542.2–56-57
Windows	542.2–65-67
Authentication Bypass	542.3–5-8
Authorization Bypass/Attacks	542.3–9-11

B

Basic Auth → Authentication	
Bearer Authentication	542.2–98
Blind Data Exfiltration	542.3–26-29
Blind Injection	542.3–21-23
Blind NoSQLi → NoSQL Injection	
Blind SQLi → SQL Injection	
Broken Function Level Authorization(BFLA)	542.3–13
Broken Object Level Authorization(BOLA)	542.3–12
Browsers	542.1–39
Burp: Breakdown	542.1–49-62

C

Cipher Suites → HTTPS	
Command Injection	542.3–16-20
Command-Line Spidering	542.1–158
Content Discovery - Forced Browsing	542.2–48-51
Content Discovery - Spidering	542.1–154
Content-Security-Policy → HTTP Response	
Cookies	542.1–90-95
HttpOnly Attribute	542.1–93
SameSite Attribute	542.1–94
Secure Attribute	542.1–92
CORS	542.4–111-112
Cross Origin Resource Sharing → CORS	
Cross-site Request Forgery → CSRF	
Cross-site Scripting → XSS	
Cryptographic Failures	542.1–139
CSP → HTTP Response	
CSRF	542.5–5-12
CSRF vs XSS	542.5–6

D

DAST	542.1–16-17
DAST: Web App Scanner	542.1–38
Data Attacks	542.4–121-122

Database Fingerprinting	542.3–108-111
Database Injection Impact	542.3–108-115
Database Metadata	542.3–110-111
DB Fingerprinting → Database Fingerprinting	
Digest Auth → Authentication	
Directory Browsing	542.2–26-27
Directory Traversal	542.3–34
DNS	542.1–107
Brute Force Scan	542.1–110
Nmap Scripts	542.1–115
nslookup → TOOLS	
Repositories	542.1–118-119
Reverse/PTR Scan	542.1–109
Zone Transfers	542.1–108
Document Object Model → DOM	
Document properties	542.4–36
DOM	542.4–5-9
Tree/Intro	542.4–5-9
DOM Event Handler Bypass	542.4–84
DOM-Based XSS → XSS	

E

Encoding URLs	542.4–54-57
---------------	-------------

F

Federated Identity & Access Protocols	542.2–75-102
Filter Bypass/Evasion	542.4–82-83
Fixation	542.2–131
Forced Browsing → Content Discovery	
Form-based Auth → Authentication	
Fuzzing	542.2–5-14

G

Google Dorks/GHDB	542.2–27
-------------------	----------

H

Harvesting → Username Harvesting	
HSTS → HTTP Response	
HTML Injection	542.4–16-19
HTTP	542.1–67-101
Certificate Virtual Host Discovery	542.1–120-121
Request	542.1–75-90
HEAD	542.1–82
Methods	542.1–75
Other CRUD	542.1–87
TRACE	542.1–83
Response	
Content-Security-Policy	542.1–101
HTTP Strict Transport Security	542.1–100
X-Frame-Options	542.1–99
Semantics	542.1–72-73
Versions/Protocols	542.1–68-71
HttpOnly Attribute → Cookies	
HTTPS	542.1–140-150

SEC542 – Web Application Penetration Tester

Confidentiality	542.1–143
Nmap to Evaluate HTTPS	542.1–148
Public Keys/Certificates & CAs	542.1–145
SSL/TLS Handshake	542.1–141
Transmission Security	542.1–140
Versions & Cipher Suites	542.1–147

I

Idempotent	542.1–75
Identifying Virtual Hosts	542.1–106
Information Leakage	542.2–22-25
Insecure Deserialization	542.5–33-50
Exploitation by Modifying Parameters ..	542.5–37
Java Example	542.5–38-46
Remote Code Execution	542.5–47-48
Integrated Windows Auth → Authentication	
Interception Proxies	542.1–41

J

JavaScript	542.4–9-13
Frameworks	542.4–117-118
Objects	542.4–9-13
Server-Side	542.4–119
JSON	542.4–123
JSON Attacks	542.4–124-125
JSON Web Tokens → JWT	
JWT	542.2–99-102

L

LFI → Local File Inclusion	
Local File Inclusion (LFI)	542.3–32-33
Logging & Monitoring Failures	542.5–28-31
Logic Flaws	542.5–13-17

M

Maunal vs Automated Testing	542.1–18-19
Metasploit	542.5–81-89
Methodology WSTG/PTES	542.1–21
Monitoring & Logging Failures	542.5–28-31

N

Non-Blind NoSQLi → NoSQL Injection	
Non-Blind SQLi → SQL Injection	
Non-relational Databases	542.3–63-64
NoSQL	542.3–65-67
Injection	542.3–65-66
Blind	542.3–104
Categories	542.3–105
Non-Blind	542.3–101-103
Payload Examples	542.3–67
NoSQLi → NoSQL Injection	

O

OAuth2	542.2–83-97
Authorization Code Flow	542.2–90-91
Grant Types	542.2–89
Implicit Flow	542.2–92-93
Vulnerabilities	542.2–96-97
OIDC → OpenID Connect	
OpenID Connect	542.2–88
OWASP Top 10	542.1–25
OWASP Top 10: LLM Applications	542.5–20-26

P

Passive Scanning	542.2–30
Pentest Post-Assessment	542.5–114-123
Pentest Preparation	542.5–100-112
Communication Plans	542.5–110-112
Pre-Engagement Specifics	542.5–105-109
Pickling → Python Pickling	
Port Scanning	542.1–127-128
Prototype Pollution	542.4–91-101
Public Keys/Certificates CAs → HTTPS	
Python	542.5–53-68
Data Types & If/Else	542.5–60
General	542.5–53-55
List & Dictionaries	542.5–62
Loops	542.5–61
Python2 VS Python3	542.5–56-57
Requests/Web Libraries	542.5–63-67
Python Pickling	542.5–71-78

R

Reflected XSS → XSS	
Remote File Inclusion (RFI)	542.3–36
Reports	542.5–115-122
REST	542.4–136
RFI → Remote File Inclusion	
Robot Exclusion Protocol	542.1–155

S

Same-Origin Policy → SOP	
SameSite → Cookies	
SAML	542.2–75-82
SAST	542.1–15
Server-side Javascript	542.4–119
Server-side Request Forgery → SSRF	
Server-side Template Injection → SSTI	
Session Management	542.2–118-131
Fixation	542.2–131
Identifiers	542.2–119
Predictability	542.2–122-125
Tamper Resistant	542.2–126
Shodan	542.1–125-126
Side-Channel Attacks	542.2–110-111

SEC542 – Web Application Penetration Tester

Slow Hashing	542.2–113
SOAP	542.4–137-138
SOP	542.4–20-28
Spidering	542.1–153-163
AJAX	542.1–161
Automated vs. Manual	542.1–156-157
CeWL → TOOLS	
SQL	542.3–50-62
Error Conditions	542.3–77-78
FROMless SELECT	542.3–84-87
Injection	542.3–51-62
Balancing	542.3–60
Blind	542.3–90-100
Blind Boolean-based	542.3–91-98
Blind Out-of-Band	542.3–100
Blind Time-based	542.3–99
Categories	542.3–105
Comment	542.3–56-57
Example	542.3–53-55
.....	542.3–58
INSERT Statements	542.3–61
Locations	542.3–70
Non-Blind	542.3–72
Non-Blind Error-based	542.3–75-79
Tautology	542.3–59
Keywords	542.3–51
NULLs & UNION	542.3–85-89
Stacked Queries	542.3–73-74
Union	542.3–80-83
SQLi → SQL Injection	
SSL/TLS Handshake → HTTPS	
SSRF	542.4–144-150
SSTI	542.4–129-132
Stored XSS → XSS	
Strict Transport Security → HTTP Response	

T

Target Profiling	542.1–124
Template Engines	542.4–127-128

Test HTTP Methods	542.1–135-136
Threat Modeling	542.1–13
Timing Attacks	542.2–112

U

Union → SQL Union	
Username Harvesting	542.2–107-114

W

Web Server Components	542.1–133-134
Web Services	542.4–135-142
Web Services Pentest Methodology	542.4–142
WSTG: Information Gathering	542.1–103
WSTG:Logic Flaws	542.5–17
WSTG:Target Profiling → Target Profiling	

X

X-Frame-Options → HTTP Response	
XML External Entity → XXE	
XMLHttpRequest	542.4–106-110
XSS	542.4–15-88
Alert() Alternatives	542.4–32-33
Bypass	542.4–83-84
DOM-Based	542.4–64-72
Injection points/Tests	542.4–75-88
Reflected	542.4–49-53
Session Abuse/Hijacking	542.4–34-38
Stored XSS	542.4–59-63
XSS vs CSRF	542.5–6
XXE	542.3–39-46

Z

ZAP: Breakdown	542.1–43-48
----------------------	-------------